RoyalBlue sandbox walkthrough

Hosted prototype · 2 November 2026 · MFB staff handover

Walk a **new customer signup**, a **forced password change**, the **staff credit desk**, and **staff onboarding** (invite → join, no BVN). Then send notes.

Landing: https://www.royalblue-mfb.com/welcome
Login: https://www.royalblue-mfb.com/login
Sign up (customers): https://www.royalblue-mfb.com/sign-up
Forgot password: https://www.royalblue-mfb.com/forgot
Staff join: https://www.royalblue-mfb.com/staff-join

Same app on Vercel: royalblue-web.vercel.app. Login with **email or Nigerian phone** + password. Use a **private window** (or logout) when you switch roles. The paid API does not spin down; a slow first hit is a deploy or network, not a free-tier sleep.

Hosting (lean live)

Company bill is Render workspace **Product's workspace**, login `product@budpay.com` (USD card). Do not look for these boxes while signed in as Gmail — that is a different account. Put API + Postgres + Redis in the **same Render project**. Production deploys from **main**; `pair-program` and other branches are for work in progress.

Box	Dashboard name	Plan	~USD / mo
API	`master-backend`	Starter · 0.5 CPU · 512 MB (does not sleep)	$7
Postgres	`royalblue-db`	Paid `0.1c-256mb` · 1 GB disk · no expiry	$6
Redis (Key Value)	`royalblue-redis`	Starter · 256 MB · `noeviction`	$10

Workspace stays **Hobby** ($0). Do not upgrade to Render Pro ($25) for go-live: it only stretches point-in-time recovery from 3 days to 7 and adds seats/logs. Compute does not change. High availability is **off** — it needs ≥1 CPU (~$40 for the DB, billed twice for the standby). Small traffic does not need that.

Confirm the database will not vanish

1. Dashboard as `product@budpay.com` → `royalblue-db` → Info.
2. Compute must read **0.1 CPU / 256 MB** (or Basic 256 MB), not Free.
3. There must be **no "Expires on …"** banner. Free instances expire after 30 days; the old Gmail sandbox DB expires **3 November 2026** — that is not this box.
4. Billing shows Postgres compute, and the USD card is on this workspace.

PITR (not HA)

Point-in-time recovery rebuilds a *new* database as it looked at a clock time you pick (for example after a dropped table). Hobby keeps the last **3 days**. Restore is a new instance + new `DATABASE_URL`, not seconds of failover. You cannot restore to a time in the last ~10 minutes. Free Postgres has no PITR; this paid one does (`royalblue-db` → Recovery).

Logical exports (Create export / `pg_dump`) are kept 7 days on Hobby. Prefer PITR for "undo"; dump to S3 if you need older copies. Never **delete** `royalblue-db` — Render drops backups with the instance.

Without HA, a node/zone failure means the API is down until Render brings that same instance back (minutes in a host blip). Money risk is covered by webhook retries, payout GET confirm, and startup reconcile — not by a standby. Redis is also a single box; balances live in Postgres.

API env: internal `DATABASE_URL` from `royalblue-db`, internal `REDIS_URL` from `royalblue-redis`. Production will not stay up if either is missing. Copy BudPay / Dojah / mail / AWS secrets from the old live API in the dashboard; do not paste them into chat or this PDF.

Passwords (everyone)

New passwords must be **12+ characters** with an uppercase letter, a lowercase letter, a number, and a symbol. Examples that work: `RoyalBlueStaff1!` · `DeskHandover2026#`. `password123` does *not* meet the rule.

Every account already in this environment was flagged to change password. You do **not** get a session on the old password.

1. On login, enter email + the current password (for the three desk logins below, that is still `password123` until you change it).
2. If the screen stays on login and says to update your password, click **Forgot password** on that same page. Do **not** reuse a code that arrived from the login attempt.
3. Enter the same email → **Send code** → use the *new* 6-digit email code → set a password that matches the checklist.
4. Return to login with the new password. New browsers may ask for a second email code (device trust).

Forgot password does not sign you in; it only replaces the password. After a successful change, `password123` will no longer work for that inbox.

Staff (saved in this environment)

These three still exist. They land on the credit desk (`/admin`), not Home. They have no customer NUBAN. They have no transaction PIN until they set one under **Me → Security** (staff cannot send customer funds without a PIN). OTP goes to the inbox you can actually open. The Chike *retail* Home login is `chikeudenze+retail@gmail.com` (same Gmail inbox) so the bare address can be the loan officer.

Role	Email	Phone	Until you change it	What to look at
Administrator	`product@budpay.com`	`08011111111`	`password123`	Pipeline, freeze, **Team (invite)**, recommend **and** decide
Loan officer	`chikeudenze@gmail.com`	`08022222222`	`password123`	Claim / recommend only — no freeze, no final decision, no invites

Role	Email	Phone	Until you change it	What to look at
Credit manager	`podijones@gmail.com`	`08033333333`	`password123`	Review, decide, freeze — no invites

Staff onboarding (no KYC)

Desk logins are **invite-only**. That is so freeze, recommend, and decide are tied to a named person — not a shared inbox. There is **no BVN, NIN, selfie, or address** on this path. This is not a customer account and does not mint a NUBAN.

Administrator invites

1. Sign in as `product@budpay.com` (after the password change above).
2. Open **Team** on the desk.
3. Fill **first name, last name, work email, Nigerian phone, role** (loan officer, credit manager, or administrator).
4. **Send invite**. A new work inbox gets a 6-digit join code. If that email is already a *customer* account, Team **promotes** it to the desk role instead of creating a second login.

Invitee finishes

1. Open /staff-join (also linked as “Join here” on login). Do not use customer **Create account**.
2. Enter the invited work email → **Email me a code** if you need another code.
3. Enter the 6-digit code and a password that meets the 12-character rule.
4. You land on the credit desk for that role. New browsers may ask for a device email code.

Unfinished invites cannot log in at `/login` until this join step is done. Actions on a file show the staff member’s name from the invite, not a generic “admin”.

Change role or remove

On **Team**, an administrator can change **Permissions** on an existing row (loan officer / credit manager / administrator). The new role applies on the next request. **Remove** takes them off the desk and ends their sessions; assigned loan files stay in the queue unassigned. You cannot remove or demote the last administrator, and you cannot remove your own login. The email can be invited again after a remove.

How customer onboarding works

Use a **new email that can receive mail**. Do not reuse old `customer@` / `starter@` accounts. If the email is already registered, login opens instead of Home. Customer passwords must meet the same 12-character rule from the start.

1. **Email.** We send a 6-digit code.
2. **Verify email.** Enter that code (not the PIN you set later).
3. **Password** (checklist on screen).
4. **Authenticator** only if the API asks for it. You can usually skip this for now.
5. **Personal or business.** Business is a wallet (money in / send), not POS or cashiers.

6. **Name and phone.**
7. **BVN and/or NIN.** Both fields are on the same screen. Prefer both; at least one is required. NIN is a regular NIN check (not advanced / not used for address). NIN must be unique across accounts. There is no skip and no phone-only "starter" account.
8. **Confirm identity ("Is this you?").** Shows the name and date of birth from that check.
9. **Live selfie.** Optional now — same step later under Account limits. Allow camera; the light should go off after you take the photo, continue, or skip. Selfie is not required on every transfer.
0. **Residential address.** You type where you live *now*, then upload a utility bill. The primary action is **Upload a utility bill**; **Send for review** sits under it. Tier 3 unlocks if the bill matches the address you typed; the more common miss goes to staff.
1. **Business details** if you chose business.
2. **6-digit transaction PIN** (create, then confirm). This is for sends and bills, not the email code.

After PIN, you land on Home. A dedicated NUBAN (virtual account) is minted when BVN *or* NIN is on file. Inbound transfers credit that VA. Outbound NIP debit the merchant wallet against the customer's ledger. Intra-RoyalBlue stays on our books.

Tiers and limits

Opening the account puts you on **Tier 1**. Limits depend on whether a confirmed BVN is linked.

Tier	What is on file	Per transfer	Daily	Max balance
Tier 1 · NIN	NIN only (no BVN)	₦30,000	₦30,000	₦300,000
Tier 1 · BVN	BVN (NIN optional)	₦50,000	₦50,000	₦300,000
Tier 2	Tier 1 + live selfie matched to the BVN or NIN photo	₦200,000	₦500,000	₦500,000
Tier 3	Tier 2 + utility bill that matches the address you typed	₦5,000,000	No daily cap	No max

Finish selfie and address later from **Account limits** (Me / Settings). If staff send a bill back, the customer is **emailed** the note and sees it in inbox / Account limits. They upload a different bill; they are not auto-dropped to a lower tier beyond staying where they were.

Home, bills, and landing

Home has **Pay bills** (balance card) and a **Bills** shortcut. There are no separate Airtime / Data tiles — those tabs live inside Pay bills with electricity. A bill that fails (error on screen) does **not** show in recent transactions.

The public `/welcome` page on a phone stacks the "Engineered for…" services and the SME copy as real text. Desktop still uses the Figma art.

Session

Access is a 15-minute httpOnly cookie. A rotating refresh cookie lasts 7 days, so closing the laptop and coming back tomorrow still works. A **visible** tab with no clicks, keys, or scrolling for **15 minutes**

signs you out and asks for the password again. Switching apps or sleeping the machine does not count as idle. Sends and bills still need the 6-digit PIN (3 wrong tries lock it).

Worth walking

1. Change a desk password via Forgot password, then sign in and land on `/admin`.
2. As administrator, invite a colleague from **Team**, or grant desk access to an existing customer email. They finish at `/staff-join` if new. Confirm their name shows on a recommend / freeze / decide.
3. Sign up a customer with a real BVN, a real NIN, and both — confirm name/DOB, type today's address, upload a bill. Check Home for a NUBAN.
4. Skip selfie and address, then complete them from Account limits. Try a send (needs the PIN you set).
5. As staff, send a proof of address back with a note. Confirm the customer email and inbox show that note.
6. Pay bills: airtime, data, and electricity from one page. Confirm a failed attempt is not in recent transactions.
7. Leave Home in a visible tab for 15 minutes with no activity — you should land on login.
8. Business signup: wallet dashboard and money in, not a till.
9. Same loan file as officer vs manager vs admin — who can claim, recommend, freeze, decide. Tenor is 3 / 6 / 12 months with daily or weekly float.

> **Do not use** old staff inboxes (`admin@royalblue.ng` , `officer@royalblue.ng` , `manager@royalblue.ng`) or old retail logins (`customer@royalblue.ng` , `starter@royalblue.ng` , PIN `123456`). They are not in this environment. Do not stay on `password123` after the first session. Do not open a customer account for desk work — use Team invite + `/staff-join` .

> **Please ignore for now:** empty bank/bill lists on a slow API, anything that looks like FX, Face ID on send, Cloudflare in front of the domain, and Render Pro / Postgres HA (lean live stays Hobby + 0.1 CPU DB).

Send: what felt unclear, what you'd expect next, and anything that looks wrong for a Nigerian MFB. Screenshots + "I was this user" is enough.

— Chike